CLOUDHERO / ASSESSMENT GUIDE

Assess Linux server hardening.

Seven areas. Evidence for each.

Collect on the server.
Analyse on a separate workstation.

SSH / Patches / Kernels / Exposure
Audit logging / Drift / Production verification

Toolkit LH-1.3 · Fixed catalogue LH-1.2
Assess existing evidence before planning changes.
Approved fixes: hardening-runbook.md
Optional disposable VM setup: lab-guide.md
Both companion guides are in the GitHub toolkit.

Adoption decision: Linux hardening baseline

Purpose: reduce unauthorized access, unpatched active software, unintended exposure and undetected configuration changes while preserving service availability. This Ubuntu-tested baseline has seven areas and 28 evidence-based controls; application security and business continuity standards remain companion requirements.

Authorize an assessment pilot first. Name the service owner and one accountable person per area. Require operator collection on the existing server, redaction and approved transfer, then AI assessment on a separate workstation without server credentials. Agree the evidence-processing boundary before sharing data. No package installation or lab reproduction is required to start. Review findings before approving fixes through the separate hardening runbook. The security owner proposes deadlines and exceptions; the service owner owns business acceptance and recovery.

Before a production change: complete the policy and change worksheets; inventory identities, software and traffic paths; prove recovery access; identify application backup/recovery evidence; approve the exact change, observation window and rollback trigger. Establish trusted configuration provenance and central logging. Missing required evidence holds the associated gate; an exception needs a named approver, compensating control and expiry and never becomes a PASS.

Separately approved remediation: test selected changes and recovery in staging; change one recoverable production canary; verify fresh access, active fixes, allowed/denied paths, log receipt and real workload behavior; observe the agreed thresholds; expand in approved batches. Stop on a failed gate. The service owner signs proceed, hold or rollback at each decision point.

Resource commitment: estimate engineering time for inventory, staging, canary verification and rollout separately. Reserve identity, network, observability and application-owner participation plus recovery capacity. Use pilot measurements to budget each additional host class and the recurring work; do not promise a universal completion time. Onboarding includes maintenance-window effort, and continuous automation still needs failure triage.

Operate and report: review patch failures, exposure and drift daily; review access and log delivery on the approved cadence; verify every material change/reboot; schedule recovery exercises. Report overdue applicable fixes, unsupported hosts, missing detection evidence, unexplained drift and recovery-test completion with denominators, owners, age and due dates. Report unknowns and stale evidence separately from compliant results. Evidence coverage is not a risk score.

Decision record: sponsor, pilot scope, accountable owners, approved policy revision, staffing/maintenance allocation, acceptance thresholds and review date. Approve expansion only after pilot acceptance and unresolved-risk review. The fictional worked change illustrates a complete decision; its numbers are not default policy.

Assess the state of an existing Linux server before deciding what to change. This guide explains the evidence needed for SSH, patch management, kernel lifecycle, firewall exposure, audit logging, configuration drift and production verification.

Toolkit LH-1.3; fixed control catalogue LH-1.2. The collection examples were tested on Ubuntu 24.04 LTS ARM64 with systemd, OpenSSH, UFW and Linux Audit. Other stacks need vendor-specific observations. The 28 control IDs, collection scripts and dated VM evidence are unchanged.

Choose the right document

- **Assessment guide - this page and PDF:** collect existing evidence on the server, transfer a redacted copy, analyse it on another machine and review the findings. There are no installation or remediation steps in this document.
- **Hardening runbook:** apply selected, separately approved fixes, then verify and recover if needed. It contains the commands that change configuration, packages or services.
- **Lab reproduction guide:** optional instructions for maintainers to provision a disposable VM and reproduce our tests. Its package installation and lab fixtures must not be run on a production target.

All three guides are included in the toolkit available through the GitHub release assets. Start here when your task is an assessment. Use the adoption brief to assign owners, evidence boundaries and a review date. This baseline is not a compliance certification or a complete application, identity, backup, encryption, secrets or workload-isolation review.

Start with an assessment

Required workflow: collect on the Linux server, transfer a redacted copy, then run the assessment prompt on a different machine. An authorized operator runs the scripts. Claude or Codex analyses the supplied evidence on your workstation. The prompt must not download or execute collectors, connect to the server, request SSH/sudo access or inspect the workstation hosting the analysis.

The scripts collect facts and perform specific deterministic checks. The prompt interprets evidence against your policy and evaluates the 28 controls. The current scripts do not independently produce a complete 28-control assessment. Neither collection nor AI assessment applies hardening fixes; remediation is a separately approved task. The modifying `lab-*` fixtures are for disposable test VMs only.

Assessment prerequisites: access and evidence, not installations

Use your existing authorized access to the intended Ubuntu server and a private location for the report. Review the two collection scripts and confirm the target before running them. The wrapper needs the operator's approved root/sudo access for privileged observations; the separate analysis workstation needs only the evidence and report tools.

Do not install packages, refresh package indexes, restart services, enable a firewall or create a new configuration baseline to begin this assessment. Missing tools, unsupported mechanisms and denied

observations stay visible in the report. Ask the owner for existing evidence or an approved read-only equivalent. Any proposed installation or configuration repair belongs in a separate remediation task. In particular, an absent UFW command does not authorize replacing the host's actual firewall manager.

The collector targets the documented Ubuntu/systemd stack. Successful collection is not a full security pass; partial collection remains useful when its limits are recorded. Reproducing our VM or running the toolkit's software tests is optional maintainer work, never a prerequisite for assessing your server.

Step 1: collect on the approved Linux server

An authorized operator obtains the toolkit from the GitHub release assets, extracts it and reviews `assess.sh` and `collect-report.sh`. On the intended Ubuntu target, from a private working directory containing the reviewed scripts, run:

```
# SERVER: run this yourself on the approved Linux target.
bash collect-report.sh ./assess.sh
```

The wrapper requests the operator's approved sudo access when needed; the AI does not receive those credentials. It creates a new `0700` directory and `0600` report at `linux-assessment.XXXXXXXX/assessment.txt`, prints the actual path and preserves the collector's exit status, including failed-collection evidence. It never reuses an existing file. The collector reads configuration without installing packages, refreshing metadata, changing settings, restarting services or rebooting. Normal access can itself create access logs.

Step 2: redact and transfer the evidence

Keep the original report private on the server. Review a separate copy and remove secrets, personal data and infrastructure details your policy does not permit sharing. Use a consistent target alias in the report and policy; preserve collection timestamps, command exit statuses and the facts needed for each check. Record redactions that limit interpretation. A missing or stale observation cannot create a PASS.

Transfer only the approved, redacted copy to a different machine using your established secure transfer method. Include the completed `policy-template.json`, target alias, workload role, environment and any approved evidence for network paths, central logging or recovery. Do not copy SSH private keys, passwords, tokens or unrestricted logs. Approve the AI service, processing location, retention and evidence classification before sharing: a cloud model processes supplied evidence even when you use it from your own workstation.

Step 3: run the prompt on your analysis workstation

On the separate machine, open your approved Claude or Codex environment. Supply the full `linux-assessment-prompt.txt`, redacted `assessment.txt`, completed policy and target context. Give the model access only to the approved evidence and assessment output area. It needs no server credentials, production shell or sudo access. A prompt is not an OS permission boundary; enforce that separation in the analysis environment.

Explicitly include this handoff instruction alongside the full assessment prompt:

```
Assess only the server described in the attached redacted evidence.
Required mode: operator collection on the server; AI analysis here.
This is a separate analysis workstation, not the assessment target.
Do not download or execute scripts, connect to the server,
request SSH/sudo access, or inspect this workstation.
Use the supplied policy and collection timestamps.
If evidence is missing, request it from the operator; never guess PASS.
Produce the 28-control report and proposed fixes only. Do not remediate.
```

If no report is supplied, the prompt asks the operator to collect, redact and transfer it first. It must not switch to live collection. For missing observations, it can propose exact read commands for the authorized operator to review and run on the server; the operator returns another redacted receipt. Only the server described in the evidence is assessed. The workstation's OS and account are irrelevant to the target's findings.

Step 4: review the report before remediation

Require a Markdown assessment and `report.json`. On the analysis workstation, an operator can validate the report structure using the local toolkit:

```
# WORKSTATION: validates the report; does not inspect the server.
python3 check-report.py --catalog controls.json report.json
```

The validator checks IDs and required evidence fields, not whether conclusions are true. Review every finding, remaining evidence gap and proposed change before arranging approved remediation. After maintenance, repeat server collection and workstation analysis with fresh evidence. The completed report describes the supplied collection times, not continuous monitoring or a fresh server scan.

Use all 28 IDs from the fixed LH-1.2 catalogue. Apply an evidence-backed, approved N/A only when the applicability condition is met. Otherwise, a proven unmet criterion is FAIL even if other observations are missing; a failed required collection is ERROR; missing required evidence or policy is MANUAL. With complete required evidence and no failed criterion, an explicit policy warning threshold produces WARN; all criteria satisfied without that warning produces PASS. Do not use WARN to hide missing evidence or an exception to convert FAIL into PASS. Report status counts and evidence coverage; neither is a security score. Additional findings do not change the denominator. Compare runs only when catalogue version and scope are the same.

1. SSH: preserve access while removing weak paths

Assess who can administer the host, how authentication works and whether access can be revoked or recovered. Effective OpenSSH settings depend on Include order and Match context; a configuration file alone is insufficient. Key/certificate and PAM MFA designs need their actual authentication chain assessed. OpenSSH configuration reference.

- **SSH-01:** require the approved authentication policy and effective configuration for every relevant user/source context, including root. No unintended password-only path is acceptable.
- **SSH-02:** require identity/key/CA owners, justified privilege, review dates and revocation/offboarding evidence.
- **SSH-03:** review an existing fresh-session receipt, the exact role-approved privileged task and the result of authorized forbidden-authentication checks. A human password prompt is not a failed automation test.
- **SSH-04:** require existing console/break-glass recovery and revocation exercise receipts against the approved objective.

The collector supplies syntax and global effective settings. It does not prove all Match contexts, identity lifecycle, fresh login or recovery. Request missing receipts from the operator; do not create users, alter authentication or initiate recovery exercises during assessment. Remediation and new exercises belong in the SSH chapter of the separate hardening runbook.

2. Patch management: define how fixes reach production

Assess software coverage, the age of the evidence, execution history and remediation deadlines. Inventory packages, third-party repositories, agents, runtimes and applications outside APT. Current vendor advisories and complete vendor package revisions determine CVE applicability; upstream version strings alone can mislead when fixes are backported. Ubuntu automatic update guidance.

- **PATCH-01:** require supported OS/kernel/source coverage, signing policy and an owner for every software channel.
- **PATCH-02:** require successful index-refresh receipts within policy, holds and both ordinary and new-dependency transaction simulations. Stale metadata cannot prove there are no updates.
- **PATCH-03:** require successful pipeline or unattended-update runs, intended origins, failure notifications and separate restart/reboot policy.
- **PATCH-04:** require applicable fix deadlines, accountable owners and unexpired exceptions for overdue exposure.

The collector uses existing metadata and simulations; it neither refreshes indexes nor installs updates. A simulation is not a completed patch transaction. Missing tools or stale metadata are evidence limitations, not an instruction to install or refresh. Ask for an existing approved update receipt. If fresh metadata requires a change, record that as a separate task before reassessment.

3. Kernel lifecycle: installed is not running

Reconcile the running kernel, installed image/meta-packages and the actual next-boot selection. Require the supported flavour and entitlement for the host's role. A retained image, an absent reboot marker or an installed livepatch client does not establish an active fix or recoverability. Canonical reboot guidance.

- **KERN-01:** require the approved kernel track/meta-package and capacity evidence for the intended transaction and recovery option.
- **KERN-02:** reconcile running, installed and next-boot states with the relevant vendor fix; name exact livepatch coverage when claimed.
- **KERN-03:** require an existing reboot/activation receipt with boot identity and successful OS/workload checks within policy.
- **KERN-04:** require an exercised fallback or image-replacement recovery path against the approved objective, including vulnerability re-triage after rollback.

The collector provides running/installed state, markers and capacity observations. It does not resolve every bootloader or demonstrate a new reboot. Request existing bootloader-selection and recovery receipts. An unresolved next boot stays open. Do not change GRUB, delete kernels, install updates or reboot for an observational assessment; those procedures belong to the kernel change runbook.

4. Firewall exposure: test the path packets take

Assess the complete permitted path across host rules, cloud firewalls, load balancers, VPN routes and container forwarding. Every listener needs an owned business purpose, source, destination, protocol and deployed address family. A listener alone does not prove internet reachability. Docker-published ports can bypass UFW's normal input path. Docker firewall guidance.

- **NET-01:** compare listeners with the owner-approved exposure inventory, including dependencies and unused services.
- **NET-02:** require effective host/cloud/container policy for IPv4 and every deployed IPv6 path.
- **NET-03:** review existing authorized allowed/denied probe receipts with known live listeners, named vantage points and deployed UDP services where relevant.
- **NET-04:** require prior-rule restoration and independent access/recovery receipts.

The starter collector observes UFW on its tested stack. If the host uses another manager, request that manager's existing policy evidence; do not install UFW to satisfy the collector. External paths remain unverified without their own receipts. Creating test listeners, adding rules or running probes is a separately scoped exercise, not part of the evidence-only AI workflow.

5. Audit logging: prove an event reaches a person

Assess event coverage, retention, transport and response separately. Journal storage limits do not define Linux Audit log retention. A running daemon does not prove required events reach a central receiver or a responsible person. Linux Audit rule reference.

- **AUD-01:** require active and persistent coverage for the approved event inventory, supported by existing redacted event receipts.
- **AUD-02:** require separate journal/audit retention and capacity policy, prior rotation/pressure tests, failure actions and loss-counter observations.
- **AUD-03:** require existing authenticated receiver receipts for every stream, wrong-peer rejection and bounded outage/recovery evidence with sequence reconciliation.
- **AUD-04:** require timestamp synchronization, central access/retention controls, routed alerts and human acknowledgement within policy.

The collector reads local rules, health, retention settings and journal metadata. It does not generate markers, rotate logs, load rules, restart daemons or interrupt forwarding. Ask for existing central-delivery and response receipts. Local files cannot close central-delivery controls. If a new exercise is necessary, leave the gap visible and schedule it separately using the logging change/test runbook.

6. Configuration drift: keep a trusted desired state

Compare observed configuration with an independently approved desired state. Names, types, ownership, permissions, symlink targets, contents and unexpected files all matter. Directory scopes must account for late overrides. Local root can rewrite both the tool and its manifest; a local MATCH is not independent attestation.

- **DRIFT-01:** require the approved scope, version and digest from a trusted source outside the assessed host.
- **DRIFT-02:** require comparison evidence covering file bytes, metadata, symlinks and extra/missing files across that approved scope.
- **DRIFT-03:** require separate expected/observed comparisons for packages, enabled services, effective SSH, active firewall and kernel track.
- **DRIFT-04:** require safe baseline-promotion/reconciliation records, failed-input protection and expiring exceptions.

The collector compares files only when the reviewed tool, scope and manifest already exist at the documented paths. If they are absent, it records the gap. Do not create or refresh a baseline during

assessment to manufacture a clean comparison. Establishing the trusted baseline is a separately approved change in the drift runbook. Investigate unexplained drift before overwriting possible evidence.

7. Production verification: close the change with evidence

Assess the evidence for a maintenance decision. The assessment itself does not authorize rollout or close a change ticket. A health endpoint returning HTTP 200 is insufficient proof of a real transaction, dependency or background job.

- **VERIFY-01:** require previously approved owners, thresholds, observation window, healthy capacity, dependencies and recovery objectives.
- **VERIFY-02:** review existing post-change OS, access, kernel, package, listener and logging receipts.
- **VERIFY-03:** require real workload correctness, background-job and dependency results within the agreed latency/error/saturation thresholds.
- **VERIFY-04:** require recorded canary acceptance, staged rollout, rollback rehearsal and an explicit owner proceed/hold/rollback decision.

The collector supplies an OS checkpoint, not application acceptance. Ask for the actual service's receipts and decision record. Do not initiate application probes or rollback from the assessment prompt. Missing production evidence stays unresolved. The separate runbook and fictional worked change explain how an authorized change team can obtain that evidence later.

Use this baseline in an individual CVE article

Keep the evergreen controls here. A CVE article should add the facts that change: affected distributions/packages, vendor fixed revisions, exploit prerequisites, current exploitation information, temporary mitigations, required restarts and a verification date. Link directly to the relevant control instead of repeating the whole hardening guide.

Use this compact response record for each affected server:

- **Applicability:** exact OS release, architecture, package/flavour, exposure and feature prerequisites; vendor advisory URL and checked-at time.
- **Fix state:** installed vendor revision, fixed vendor revision, active process/kernel revision, and any livepatch coverage. Vendor backports mean upstream version strings alone can mislead.
- **Action:** remediation owner, deadline, canary, maintenance requirements, mitigation expiry and tested recovery path.
- **Proof:** post-change version evidence, required reboot/restart evidence, application checks, exposure checks and central log receipt.

Use explicit outcomes: affected; not affected with vendor evidence; fixed on disk but restart pending; fixed and active; or unknown. Hardening can reduce exploit paths, but it is not proof that a vulnerability is fixed. Consult the current Ubuntu security notices or the applicable distribution vendor's advisory for each CVE.

A repeatable operating cadence

At provisioning, establish ownership, support coverage, access, logging, approved configuration and recovery. For each advisory, assess applicability and prioritize the specific fix. During maintenance, stage updates, verify the canary, reboot or restart when required and record acceptance evidence. On your agreed recurring schedule, review stale exceptions, patch failures, new exposure, log delivery and configuration drift.

Turn the guide into an owned service

The companion operating matrix assigns each area an accountable role, review trigger and evidence obligation. Suggested starting cadences are daily patch/exposure/drift monitoring, monthly access and log-delivery review, and acceptance checks for every change or reboot. They are planning examples; the organization's policy can require a different interval.

The security and service owners set patch deadlines using active exploitation, reachable attack paths, vendor severity and business impact. Record numeric deadlines in the policy worksheet; blank values remain MANUAL. For an urgent exploited exposure, identify the incident owner immediately, assess containment and establish an explicit remediation deadline rather than waiting silently for the routine window.

Track decision-useful measures with clear denominators: overdue applicable patches / all applicable patches; unsupported hosts / managed hosts; hosts with current central-delivery evidence / hosts requiring it; unresolved security-sensitive drift / assessed hosts; successful recovery exercises / scheduled exercises. Show stale and unknown evidence separately. Neither a green host count nor assessment coverage measures residual risk by itself.

Every exception needs an affected control ID, scope, reason, owner, compensating control, approver, expiry and revalidation date. Expired exceptions reopen the finding. Before adopting this seven-area baseline, link the organization's separate standards for least privilege, AppArmor/SELinux, secrets, backups, encryption, supply-chain verification and workload isolation. Those domains are prerequisites or companion reviews, not implicitly certified by this guide.

For other distributions, preserve these outcomes but use the vendor's supported package manager, firewall manager, service names, audit architecture and kernel lifecycle. RHEL has advisory-aware security update workflows; Amazon Linux, Debian and SUSE have their own support and packaging rules. This edition does not claim VM validation for those platforms. RHEL security update documentation.

Validation and edition notes

The companion lab record names the image digest, architecture, package versions, running kernel before and after maintenance, exact scripts and observed assertions. It separates successful lab checks from production checks that need your infrastructure. The reusable assessment prompt evaluates the same 28 controls across seven areas and requires evidence for every conclusion.

Treat this as a maintained baseline: review it when the operating-system support window, OpenSSH behavior, package/update mechanism or firewall backend changes. Re-run the relevant lab after changing executable guidance in the companion runbook or fixtures. Retain dated test results without turning those package versions into permanent recommendations.

Operating ownership matrix

SSH access
Accountable role: Identity owner
Executor: Platform engineer
Starting cadence: After access changes; monthly access review

Patch management
Accountable role: Platform owner
Executor: Platform engineer; security triage analyst
Starting cadence: Daily update/failure review; on every relevant advisory

Kernel lifecycle
Accountable role: Platform owner
Executor: Platform engineer; application verifier
Starting cadence: After kernel change/reboot; monthly support review

Firewall exposure
Accountable role: Network owner
Executor: Network engineer; service engineer
Starting cadence: After network changes; daily exposure drift monitoring

Audit and logging
Accountable role: Security operations owner
Executor: Observability engineer; on-call responder
Starting cadence: Continuous pipeline monitoring; monthly delivery exercise

Configuration drift
Accountable role: Configuration owner
Executor: Configuration engineer; service engineer
Starting cadence: After changes; daily comparison

Production verification
Accountable role: Service owner
Executor: Platform engineer; application verifier
Starting cadence: Every rollout and reboot; periodic recovery exercise

Complete the policy template with actual owners, deadlines, acceptance thresholds and escalation paths. The cadences are starting examples; incomplete fields remain unresolved decisions.

Fixed assessment catalogue LH-1.2

Emit exactly these 28 IDs. PASS requires every criterion. Missing evidence is MANUAL; collection failure is ERROR. Do not convert an exception into a PASS or improve coverage by omitting a check.

SSH-01 / Effective authentication

PASS requires: Root login is disabled; every user/source Match context enforces the approved key/certificate or MFA chain; no unintended password-only route.

Evidence: sshd -t; sshd -T -C for each approved context and root; approved authentication policy.

Applicability: Always applicable to a server offering SSH.

SSH-02 / Identity and key lifecycle

PASS requires: Every privileged identity/key/CA has an owner, justified privilege, revocation path and current access review.

Evidence: Redacted identity inventory, sudo scope, key/CA lifecycle and offboarding evidence.

Applicability: Always applicable; non-SSH administration uses equivalent identity evidence.

SSH-03 / Fresh access verification

PASS requires: A new non-multiplexed session and required sudo action succeed after change; forbidden authentication is rejected in an authorized test.

Evidence: Timestamped new-session receipt, effective forbidden-authentication policy and bounded negative test.

Applicability: Always applicable when SSH is the management path.

SSH-04 / Recovery and revocation

PASS requires: The approved console/break-glass route and an access-revocation exercise meet the organization recovery objective.

Evidence: Dated recovery/revocation exercise, responsible owner, credential storage and retrieval record.

Applicability: Always applicable; do not perform a recovery drill during observational assessment.

PATCH-01 / Supported sources and coverage

PASS requires: OS release, kernel track and repositories are supported, signatures verified and every software channel has an update owner.

Evidence: Release/support evidence, repository signing configuration, entitlement status, third-party/runtime inventory.

Applicability: Always applicable.

PATCH-02 / Fresh update inventory

PASS requires: All required indexes have a successful refresh within policy; all pending/held packages are identified using both ordinary and new-dependency simulations.

Evidence: Refresh receipt for every source, metadata age, apt holds, simulations, dpkg audit.

Applicability: Always applicable; use vendor equivalents outside Ubuntu.

PATCH-03 / Patch execution evidence

PASS requires: The approved pipeline or unattended policy has successful runs, intended origins, monitored failures and controlled restart/reboot behavior.

Evidence: Effective allowed origins and periodic settings, timer/job state, successful transaction and failure alert receipt.

Applicability: Always applicable; a managed pipeline is a valid alternative to unattended installs.

PATCH-04 / Remediation deadlines

PASS requires: Every applicable overdue fix has an approved, unexpired exception; no unowned exposed vulnerability remains.

Evidence: CVE/package mapping, exposure, owner, due date, exception approver and compensating control.

Applicability: Always applicable; no open findings still requires the current inventory and policy.

KERN-01 / Kernel track and boot capacity

PASS requires: The approved supported flavour/meta-package is present; boot/root free space supports the reviewed transaction and recovery image.

Evidence: Package/candidate records, vendor support track, bootloader type, disk capacity.

Applicability: Always applicable to hosts; a container points to an identified host owner, not an automatic N/A.

KERN-02 / Installed and active fix state

PASS requires: Running kernel, installed fixed revision and actual next-boot selection are reconciled; livepatch claims name specific coverage.

Evidence: uname -r; package ownership/version; actual bootloader entries; vendor advisory; livepatch evidence if used.

Applicability: Always applicable to the assessed host. Livepatch itself can be unused without making the control N/A.

KERN-03 / Verified reboot activation

PASS requires: Required reboot is completed within policy and the intended kernel is active with working drivers, networking and workloads.

Evidence: Changed boot ID, post-boot kernel, restart-needs check and workload acceptance record.

Applicability: For a maintenance assessment. For a baseline audit, use a recent approved exercise; absent evidence is MANUAL.

KERN-04 / Fallback boot recovery

PASS requires: A retained recovery option has been exercised and can restore service within the approved recovery objective.

Evidence: Actual fallback/recovery exercise, console access, application recovery and vulnerability re-triage record.

Applicability: Always applicable; an image-replacement strategy can substitute for an older-kernel boot.

NET-01 / Approved exposure inventory

PASS requires: Every listener maps to an owned service with expected protocol, family, source and destination; unused services are removed or explicitly excepted.

Evidence: Service-exposure inventory and ss listener comparison.

Applicability: Always applicable, including non-public hosts.

NET-02 / Effective host and platform policy

PASS requires: Host rules, cloud/network policies and container forwarding permit only the approved paths across IPv4 and every deployed IPv6 path.

Evidence: Effective rules, management-source restrictions, cloud/load-balancer evidence and container mappings.

Applicability: Always applicable. Undeployed layers need an evidence-backed reason, not guessed absence.

NET-03 / Allowed and denied path proof

PASS requires: Authorized probes confirm expected access and rejection from named management and untrusted vantage points, including deployed UDP services.

Evidence: Source/destination/protocol/family matrix with live-listener positive and negative results.

Applicability: Always applicable; no external vantage point means MANUAL for external exposure.

NET-04 / Firewall recovery

PASS requires: The prior approved rules can be restored through a tested independent access path and required services recover.

Evidence: Rollback exercise, saved exact policy and post-restore access/health evidence.

Applicability: Always applicable; observational mode consumes existing evidence only.

AUD-01 / Useful event coverage

PASS requires: Persistent audit rules and authentication/privilege logs cover the approved event inventory and controlled events are retrievable.

Evidence: Loaded and persistent rules, event inventory, redacted audit/authentication event examples.

Applicability: Always applicable; alternative audit mechanisms require documented equivalent evidence.

AUD-02 / Retention and pressure behavior

PASS requires: Journal and audit-log limits separately match policy; rotation, free-space/queue alerts and failure actions are verified under safe test conditions.

Evidence: Effective journald and auditd settings, retention calculation, rotation result, disk/queue alert exercise.

Applicability: Always applicable; a configured limit alone is not a retention guarantee.

AUD-03 / Authenticated central delivery

PASS requires: Required event streams reach an authenticated central receiver; a failed certificate is rejected and a bounded receiver outage is detected and recovered.

Evidence: TLS peer verification, unique marker receipt, audit-event receipt, negative TLS result, outage/recovery and queue evidence.

Applicability: Always applicable for this production baseline; local-only logging is an exception, not N/A.

AUD-04 / Actionable detection

PASS requires: Synchronized timestamps, central access/retention controls and a routed alert with human acknowledgement meet policy.

Evidence: Clock status, receiver retention/access policy, alert receipt/acknowledgement and response owner.

Applicability: Always applicable; a lab sink is not proof of production alert handling.

DRIFT-01 / Trusted desired state

PASS requires: The approved baseline, scope and revision are stored independently of the host and tied to an authorized change.

Evidence: Reviewed repository/artifact revision, external manifest digest, scope and approver.

Applicability: Always applicable; a root-writable local manifest alone cannot pass.

DRIFT-02 / Complete file inventory

PASS requires: Approved paths match names, types, owners, permissions, symlink targets and file content; extra/missing files are detected.

Evidence: Inventory comparison plus positive/negative regression evidence.

Applicability: Always applicable; explicit exclusions must have owners and reasons.

DRIFT-03 / Runtime and package drift

PASS requires: Effective SSH policy, active firewall, enabled services, installed packages and kernel track match the approved inventory.

Evidence: Versioned runtime/package/service inventories and independent comparisons.

Applicability: Always applicable; filesystem hashes alone cannot pass.

DRIFT-04 / Safe baseline promotion

PASS requires: Missing/unreadable/unsupported input prevents baseline replacement; reconciliation preserves the approved record and exceptions expire.

Evidence: Atomic promotion negative test, restoration test, approval record, drift ticket/exception expiry.

Applicability: Always applicable.

VERIFY-01 / Defined acceptance and recovery

PASS requires: Named owner has approved success thresholds, observation window, rollback trigger, recovery objective and maintenance dependencies before change.

Evidence: Completed change worksheet and recent application recovery evidence.

Applicability: Always applicable.

VERIFY-02 / OS and access acceptance

PASS requires: Fresh admin access, intended kernel, completed package state, expected listeners, healthy critical units and logging pass after change/reboot.

Evidence: Timestamped pre/post checks and unresolved-error list.

Applicability: Always applicable; known pre-existing failures require an approved exception.

VERIFY-03 / Workload acceptance

PASS requires: A representative user transaction, background job and dependency path meet agreed correctness/latency/error thresholds during the observation window.

Evidence: Actual transaction/job receipts and monitoring comparison to the recorded baseline.

Applicability: Always applicable; a synthetic lab application does not certify the real workload.

VERIFY-04 / Controlled rollout decision

PASS requires: Canary acceptance, rollback rehearsal, staged rollout and final owner sign-off are recorded; failed gates stop advancement.

Evidence: Release decision record with canary count, gates, rollback result and sign-off.

Applicability: Always applicable; assessment alone never authorizes a production rollout.

Lab validation record

Historical implementation evidence from the disposable VM. Reproduction is optional maintainer work described in lab-guide.md; it is not a prerequisite for assessing an existing server. This documentation revision does not claim a new VM run.

Tested on 3–4 November 2026 in a real Ubuntu 24.04.5 LTS ARM64 VM through Lima 2.2.1 and Apple Virtualization Framework: 2 CPUs, 3 GiB RAM, 16 GiB disk, no host directory mounts. The active kernel moved from 6.8.0-142 to 6.8.0-147; a one-time fallback boot exercised 142 before returning to 147. Results below describe lab mechanisms, not complete production-control outcomes.

SSH - PASS · LAB
Fresh pinned SSH identity and exact approved privilege check passed; root/password-only paths rejected. Separate password-required and restricted automation roles behaved correctly and were removed.

Patching - PASS · LAB
70 packages upgraded, followed by 4 kernel meta-packages and 6 dependencies. Both final simulations, timers and reboot policy were checked; a later strict index refresh and TLS module install succeeded.

Kernel lifecycle - PASS · LAB
Activated 6.8.0-147, booted the retained 6.8.0-142 once through GRUB, then returned to 147 with distinct boot IDs and no failed units.

Firewall exposure - PASS · LAB
Independent namespaces proved allowed/denied SSH and live TCP 443/8080 filtering over IPv4/IPv6. Exact saved firewall files were restored.

Audit logging - PASS · LAB
Audit capture/rotation retained prior evidence. Mutual TLS, audit/syslog inputs and wrong-peer rejection passed. All 300 queued sequence IDs reconciled with no gaps/duplicates; real queue pressure reached a local fixture alert sink.

Configuration drift - PASS · LAB
Expanded 185-entry inventory matched. Added APT, repository, journald, UFW, sudo and rsyslog overrides were detected; private report capture and collector status classification passed.

Production verification - PASS · FIXTURE
OS/access checks passed after recovery. A synthetic transaction detected a wrong result despite HTTP 200, held advancement and passed after rollback. Actual service acceptance remains open.

One Ubuntu ARM64 VM is not a fleet certification. Cloud/internet/container/UDP paths, PAM MFA, livepatch, production load, disk-full behavior and external alert routing, central retention and human acknowledgement, independent baseline trust, identity governance, backup/data recovery and real production transactions require separate evidence. Lab TCP/TLS recovery is not an exactly-once guarantee. The worked assessment keeps these production requirements unresolved against all 28 fixed controls.

Get the full prompt, hardening runbook, lab guide and editable sources from the GitHub release assets. Collect on the server; analyse the redacted report on a separate workstation. Use the runbook only for approved changes and the lab guide only for optional disposable-VM reproduction.